PRAVEEN V 241901082

Exercise 11
Cross-Site Request Forgery (CSRF)

AIM

To investigate a CSRF vulnerability in an authorized training application by identifying a state-changing request, examining its CSRF protection, and demonstrating the application's behavior during the exercise.

PROCEDURE

a) Identifying a State-Changing Request and Examining CSRF Protection

1. Open the target web application in a browser and log in with valid credentials.
2. Open Burp Suite and set the browser proxy to route through it (127.0.0.1:8080) with Intercept on.
3. Perform a state-changing action in the application (e.g., change email/password, transfer funds, post a comment).
4. Capture the corresponding HTTP request in Burp Suite and examine it closely.
5. Check the request for the presence of a CSRF token (a hidden field or custom header such as csrf_token or authenticity_token).
6. Check the response cookies for the SameSite attribute and check the application for any Referer/Origin header validation.

7. Note whether the state-changing request relies only on the session cookie with no CSRF token, which indicates the application is vulnerable.

b) Demonstrating the CSRF Exercise

1. Using the captured request, create an HTML page containing an auto-submitting form that replicates the same state-changing request (same parameters, same method).
2. Host this HTML page locally or open it directly in the browser while the victim session is still logged in to the target application.
3. Open the crafted HTML page in the same browser (simulating the victim visiting a malicious page) and observe whether the form submits automatically.
4. Check the target application to verify whether the state change (e.g., email/password change) occurred without the user knowingly submitting the request.
5. Record whether the CSRF attack succeeded or was blocked, and note the reason (token missing/validated, SameSite cookie, Referer check).

OBSERVATION TABLE

S.No	**Request Examined**	**CSRF Token Present**	**SameSite Cookie**	**Attack Result**
1	Change email (POST /account/email)	No	None	Attack succeeded
2	Change password (POST	Yes	Strict	Attack

S.No	Request Examined	CSRF Token Present	SameSite Cookie	Attack Result
	/account/password)			blocked
3	Post comment (POST /guestbook.php)	No	None	Attack succeeded

OUTPUT

Captured vulnerable request (Burp Suite):

POST /account/email HTTP/1.1

Host: target-app.local

Cookie: PHPSESSID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e

Content-Type: application/x-www-form-urlencoded

email=attacker@example.com

Crafted CSRF HTML page:

```
<html>
  <body onload="document.forms[0].submit()">
    <form action="http://target-app.local/account/email" method="POST">
      <input type="hidden" name="email" value="attacker@example.com">
    </form>
  </body>
</html>
```

Result after exercise:

Victim account email changed to attacker@example.com without consent

RESULT

Thus, a CSRF vulnerability in the authorized training application was successfully investigated. A state-changing request lacking a CSRF token was identified, and the exploit demonstrated that the application could be forced to perform an unauthorized state change on behalf of a logged-in victim.